

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No. 1	Page No.: Page 1 of 8



Cybersecurity Audit minimum Requirements Document
For Electronic Invoice Machine, ERP & POS Device Security
Compliance check list

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 2 of 8

Introduction

In today's technology-driven business environment, the security and compliance of critical systems such as Enterprise Resource Planning (ERP), Point of Sale (POS) devices, and electronic invoice machines are paramount. These systems handle sensitive financial, personal, and transactional data frequently targeted by malicious actors. To ensure their integrity, confidentiality, and availability, it is essential for regulatory body Information Network Security Administration (INSA) to perform rigorous security assessments.

INSA should base its security checks on the comprehensive Compliance Metrics Checklist designed to evaluate the security posture of ERP, POS, and electronic invoice systems, including associated peripherals. This checklist covers key areas such as governance, device security, data protection, secure communication, access controls, update mechanisms, and physical security. By adopting this structured framework, INSA can effectively guide auditors, cybersecurity professionals, and IT administrators in performing thorough and consistent evaluations.

Through systematic validation of each compliance area, INSA helps organizations identify vulnerabilities, mitigate risks, and maintain robust defenses against evolving cyber threats, while ensuring adherence to industry best practices, local regulations, and organizational policies. This approach supports the broader goal of protecting critical infrastructure and fostering trust in digital financial and business systems.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 3 of 8

#	Compliance Area	Metric Requirement	Detailed Explanation	Compliant (Yes/No)	Evidence / Remarks
1	Governance & Scope Adherence	Scope Covered	Ensure audit covers all devices: ERP, POS, electronic invoice machines, and peripherals to avoid blind spots.		
	1.1	Compliance Objective	No critical systems/modules are skipped; all authorized scope is thoroughly tested.		
	1.2	Testing Ethics	Testing must not disrupt system integrity, availability, or confidentiality; ethical hacking standards followed.		
	1.3	Documentation	Findings are clearly and accurately documented without false or misleading assurances.		
2	Secure Boot	Bootloader Signature Verification	Bootloader uses hardware-protected cryptographic keys to verify firmware authenticity before execution.		
	2.1	Boot Halting	Device halts boot process if firmware verification fails, preventing tampered firmware execution.		
	2.2	Tamper Attempt Detection	Attempts to bypass secure boot (e.g., glitching) are detected and logged.		
3	Firmware & Software Integrity	Firmware Encryption	Firmware stored on the device is encrypted using strong algorithms (AES-256 or better) to prevent unauthorized extraction.		
	3.1	Signature Validation	Firmware is digitally signed and the signature is validated during boot to ensure integrity.		

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 4 of 8

	3.2	Secure Key Storage	Cryptographic keys are stored in tamper-resistant hardware components such as TPM or Secure Element.		
4	Hardware Security	Debug Interface Lockdown	Debug ports (UART, JTAG, SPI) are disabled or strictly access-controlled to prevent hardware-level attacks.		
	4.1	Tamper Detection	Sensors detect physical tampering events (e.g., opening device case) and log them for audit.		
	4.2	Physical Protection	Sensitive chips/components are physically protected with shielding, epoxy, or other means to deter probing.		
5	Data Security	Encryption at Rest	Fiscal and sensitive data are encrypted on storage to protect against theft or device loss.		
	5.1	No Plaintext Storage	Sensitive fields (e.g., taxpayer ID) are never stored in plaintext but are encrypted or masked.		
	5.2	Retention & Deletion Policy	Defined policies for data retention periods and secure deletion, compliant with legal/regulatory requirements.		
6	Secure Communication	TLS 1.3+ Used	All data in transit is encrypted using the latest TLS protocols (TLS 1.3 or newer) for confidentiality and integrity.		
	6.1	mTLS Authentication	Mutual TLS ensures both client and server authenticate each other to prevent MITM attacks.		
	6.2	Insecure Protocols Disabled	Insecure legacy protocols (HTTP, FTP, Telnet) are disabled to eliminate attack vectors.		

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No.: 1	Page No.: Page 5 of 8

7	Access Control	MFA Enabled	Multi-factor authentication adds an extra security layer beyond passwords to protect access.		
	7.1	Session Control	Sessions timeout after inactivity and accounts lock after repeated failed login attempts to prevent unauthorized access.		
	7.2	Role-Based Access (RBAC)	Access permissions are assigned strictly based on user roles, enforcing least privilege principles.		
8	Provisioning & Key Management	Secure Key Injection	Keys are securely injected during manufacturing using HSMs or equivalent secure methods to prevent key leakage.		
8.1	8.1	Unique Keys per Device	Each device has unique cryptographic keys, avoiding shared or default keys that risk mass compromise.		
	8.2	Key Rotation/Revocation	Mechanisms exist to securely rotate or revoke keys if compromised or as part of regular maintenance.		
9	OTA Update Security	OTA Signing & Encryption	Over-the-air updates are signed and encrypted to ensure authenticity and confidentiality.		
	9.1	Version Check & Validation	Device verifies update version and blocks downgrade attacks to prevent reverting to vulnerable firmware.		
	9.2	Anti-Rollback	Prevents reinstallation of older, vulnerable firmware versions to avoid exploitation.		
	9.3	Update Logging	All update events (installations, failures) are securely logged for accountability and auditing.		

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title: Cybersecurity Audit Requirements Document Guideline		Issue No.: 1	Page No.: Page 6 of 8

10	Device Lockdown	Application Whitelisting	Only vendor-approved and authorized software can run, preventing unauthorized or malicious apps.		
	10.1	Command-Line Restrictions	Command line interfaces are disabled or restricted unless explicitly required and secured.		
	10.2	Least Privilege	Users and processes only have the minimal privileges necessary to perform their functions, reducing risk.		
11	Fiscal Data Protection	Immutable Invoice Logs	Invoice logs are stored in write-once-read-many (WORM) format and digitally signed to prevent modification.		
	11.1	Secure Timestamping	Transactions and logs are timestamped using a trusted and secure time source to ensure accuracy and prevent tampering.		
	11.2	Offline Invoice Caching	Invoice data cached offline is encrypted and automatically synchronized with the central system once connectivity is restored.		
12	ERP-POS Integration Security	Secure APIs Used	APIs between ERP and POS use secure protocols like OAuth2 or JWT with TLS 1.3+ encryption to protect data.		
12.		Input Validation	All user and system inputs are strictly validated and sanitized to prevent injection and other attacks.		
	12.1	Role Separation	Operational, financial, and administrative roles are separated to minimize risk of fraud and unauthorized actions.		
13	Physical Security	Tamper-Evident Hardware	Devices have physical seals and tamper-evident features, with custody logs maintained to track device handling.		

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No.: 1	Page No.: Page 7 of 8

	13.1	Tamper Detection Response	Systems alert administrators or wipe/shutdown automatically upon detecting tampering attempts.		
	13.2	Power/Surge Protection	Backup power supplies and surge protectors are installed to avoid damage or data loss due to power issues.		
14	Testing & Validation	Pen Testing Conducted	Realistic penetration tests simulate attacker behavior to identify and fix vulnerabilities before exploitation.		
14.	14.1	Firmware Analysis	Firmware is reverse-engineered and analyzed to detect hidden backdoors or security flaws.		
	14.2	API Testing	APIs are tested against OWASP Top 10 vulnerabilities, such as injection and broken authentication.		
15	Standards Compliance	PCI-DSS	Payment Card Industry Data Security Standards are met for all payment card data handled by the system.		
15		NON PCI-DSS (Proprietary)	Non-PCI-DSS (proprietary) card payment systems (loyalty cards, voucher cards, wallet cards, local payment cards, and the alike) should comply with globally accepted security standards like those listed under PCI-DSS and the alike.		
15.	15.1	ISO/IEC 27001	Information Security Management System (ISMS) policies and controls are audited and implemented as per ISO standards.		
	15.2	ISO/IEC 15408	Security Functional and Assurance Requirements are validated under Common Criteria certification.		
	15.3	Local Fiscal Authority	The system complies fully with national fiscal regulations including invoicing and audit requirements.		

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title: Cybersecurity Audit Requirements Document Guideline		Issue No.: 1	Page No.: Page 8 of 8

16	Audit Deliverables	Vulnerability Report	Detailed reports include proof-of-concept exploits and CVSS severity scores for effective risk assessment.		
16	16.1	Compliance Checklist	Completed checklist cross-referenced with industry standards to demonstrate thorough coverage and compliance.		
	16.2	Certification Documents	Relevant certifications (e.g., ISO27001, PCI-DSS) are submitted or in process to prove compliance.		